KADIRHAN GÜNEYLİ

CYBERSECURITY / LAB REPORTS



SECURITY OPERATIONS / LAB 001

EDR/XDR OLAY İNCELEME RAPORU

TrendAI Vision One | Office Makro Simülasyonu

SOC Investigation & Custom Detection

HAZIRLAYAN / KADIRHAN GÜNEYLİ

12 EKİM 2026 • VERSİYON 1.0

İÇİNDEKİLER

1. YÖNETİCİ ÖZETİ 3

2. AMAÇ VE KAPSAM 3

2.1. Çalışmanın Amacı 3

2.2. Çalışmanın Kapsamı 3

3. LABORATUVAR ORTAMI VE KURULUM 4

3.1. Laboratuvar Altyapısı 4

3.2. Trend Micro Endpoint Agent Kurulumu 4

3.3. Telemetri Doğrulaması 5

4. PHISHING SENARYOSU VE MAKRO SİMÜLASYONU 5

4.1. Phishing E-Postasının Analizi 5

4.2. Office Makro Simülasyonu 6

5. TEKNİK OLAY ANALİZİ 7

5.1. Process Creation Analizi 7

5.2. Komut Çalıştırma Bulguları 8

5.3. AMSI Telemetrisinin İncelenmesi 9

6. DETECTION ENGINEERING 10

6.1. İlk Tespit Sonucu 10

6.2. Custom Detection Filter 10

6.3. Custom Detection Model 11

7. WORKBENCH ALERT INVESTIGATION 12

7.1. Alarm Bilgileri 12

7.2. Timeline Analizi 12

7.3. Impact Scope 13

7.4. In-depth Investigation 13

8. MITRE ATT&CK ANALİZİ 15

9. SOC ANALİST DEĞERLENDİRMESİ 15

10. CASE CLOSURE 15

11. SONUÇ VE ÖNERİLER 17

1. YÖNETİCİ ÖZETİ

11 Ekim 2026 tarihinde gerçekleştirdiğim laboratuvar çalışmasında, TrendAI Vision One EDR/XDR platformu üzerinden şüpheli aktivitelerin tespitini ve analizini amaçladım. İlk olarak Sysmon kurulu Windows 10 Pro sanal makinesine Trend Micro Endpoint Agent kurulumunu gerçekleştirdim.

Ardından phishing temalı bir e-posta senaryosu hazırladım. E-postanın gönderen adresini ve SPF, DKIM, DMARC sonuçlarını inceledim. Gmail'in makrolu dosyayı engellemesi nedeniyle makro çalıştırma aşamasını sanal makinede ayrıca gerçekleştirdim.

Hazırladığım Word makrosu aracılığıyla whoami, hostname, ipconfig /all ve tasklist komutlarını çalıştırarak sistem keşfi davranışlarını simüle ettim. Bu aktiviteleri endpoint telemetrisi üzerinden doğruladım.

İlk testte Workbench alarmı oluşmadığından özel bir detection filtresi ve modeli geliştirdim. Simülasyonu tekrarladığımda alarmın tetiklendiğini gördüm. Ardından Timeline, Impact Scope ve In-depth Investigation üzerinden olayı analiz ettim.

İnceleme sonucunda şüpheli davranışların gerçekten gerçekleştiğini, ancak yetkili bir laboratuvar testinden kaynaklandığını belirledim. Bu nedenle vakayı Benign True Positive — Pen Test Result olarak sınıflandırarak kapattım.

---

2. AMAÇ VE KAPSAM

2.1. Çalışmanın Amacı

Bu laboratuvarın temel amacı, gerçek bir SOC analistinin karşılaşabileceği güvenlik olaylarını kontrollü bir ortamda simüle ederek uygulamalı deneyim kazanmaktır.

Bu doğrultuda TrendAI Vision One EDR/XDR platformunu kullanarak şüpheli aktiviteleri tespit etmeyi, güvenlik alarmlarını incelemeyi, olayın nasıl gerçekleştiğini analiz etmeyi ve elde edilen kanıtlara göre bir SOC vakasını sonuçlandırmayı hedefledim.

2.2. Çalışmanın Kapsamı

2.2. Çalışmanın Kapsamı

Bu çalışmada phishing temalı bir e-posta senaryosu hazırlanmış ve kontrollü laboratuvar ortamında Word makrosu aracılığıyla sistem keşfi komutları çalıştırılmıştır.

TrendAI Vision One üzerinden endpoint aktiviteleri ve AMSI kayıtları incelenmiş, özel bir tespit modeli oluşturularak alarm üretilmiştir. Ardından olay zaman çizelgesi, process ilişkileri ve etki kapsamı analiz edilerek SOC vaka yönetimi süreci uygulanmıştır.

Çalışma ağırlıklı olarak **tespit, analiz ve vaka yönetimine** odaklanmıştır. Kalıcılık, yatay hareket, veri sızdırma ve endpoint izolasyonu gibi aşamalar uygulamalı olarak test edilmemiştir.

---

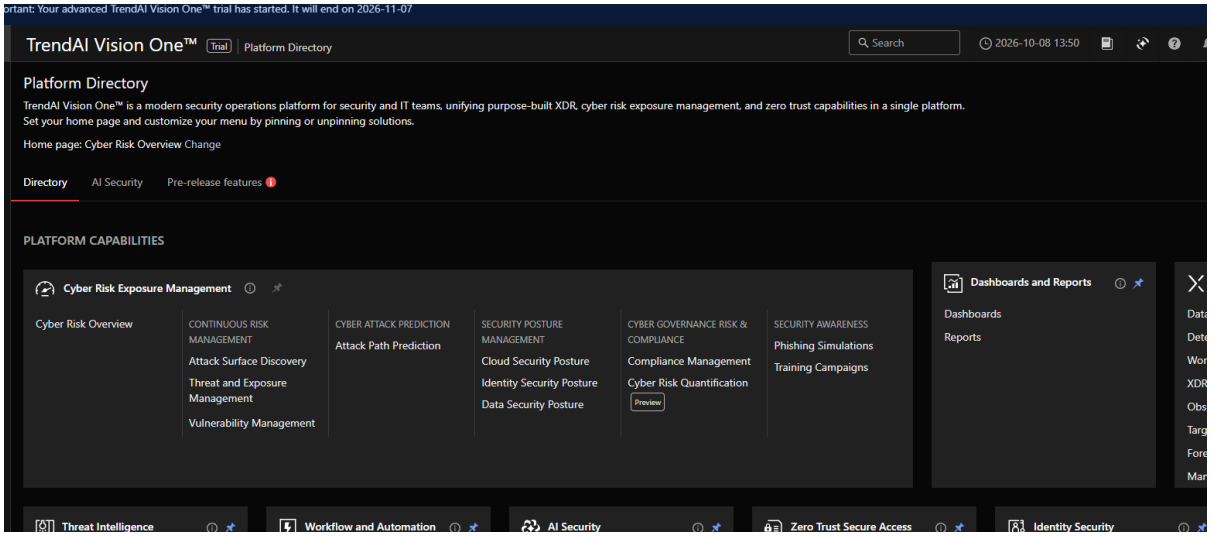
3. LABORATUVAR ORTAMI VE KURULUM

3.1. Laboratuvar Altyapısı

Çalışma, VMware üzerinde oluşturulmuş sanal bir Windows laboratuvar ortamında gerçekleştirilmiştir. Windows 10 Pro istemcisi, Active Directory etki alanına bağlı olarak yapılandırılmıştır.

Bileşen	Açıklama
Sanallaştırma	VMware
İstemci işletim sistemi	Windows 10 Pro
Domain Controller	Windows Server 2019
Domain	lab.local
Endpoint adı	WIN10-CLIENT
Endpoint IP	192.168.192.138
Endpoint kullanıcısı	LAB\kadirhan
Güvenlik platformu	TrendAI Vision One
Ek loglama aracı	Sysmon

3.2. Trend Micro Endpoint Agent Kurulumu



Şekil 1. TrendAI Vision One platform dizini ve XDR özelliklerine erişim.

İlk olarak TrendAI Vision One platformunda bir deneme hesabı oluşturulmuştur. Ardından, daha önceden Sysmon kurulumu yapılmış olan Windows 10 Pro sanal makinesine Trend Micro Endpoint Agent yüklenmiştir.

Kurulum sonrasında cihazın TrendAI Vision One konsoluyla bağlantısı ve endpoint aktivitelerinin platforma iletildiği kontrol edilmiştir.

3.3. Telemetri Doğrulaması

Endpoint ajanının düzgün çalıştığını doğrulamak amacıyla Windows üzerinde test amaçlı process aktiviteleri oluşturulmuştur.

XDR Data Explorer üzerinden ilgili olay kayıtları incelenmiş; process adı, PID, komut satırı ve process ilişkileri gibi bilgilerin görüntülenebildiği doğrulanmıştır.

Bu aşamanın tamamlanmasıyla laboratuvar ortamı, Office makrosu üzerinden gerçekleştirilecek şüpheli komut çalıştırma simülasyonuna hazır hâle getirilmiştir.

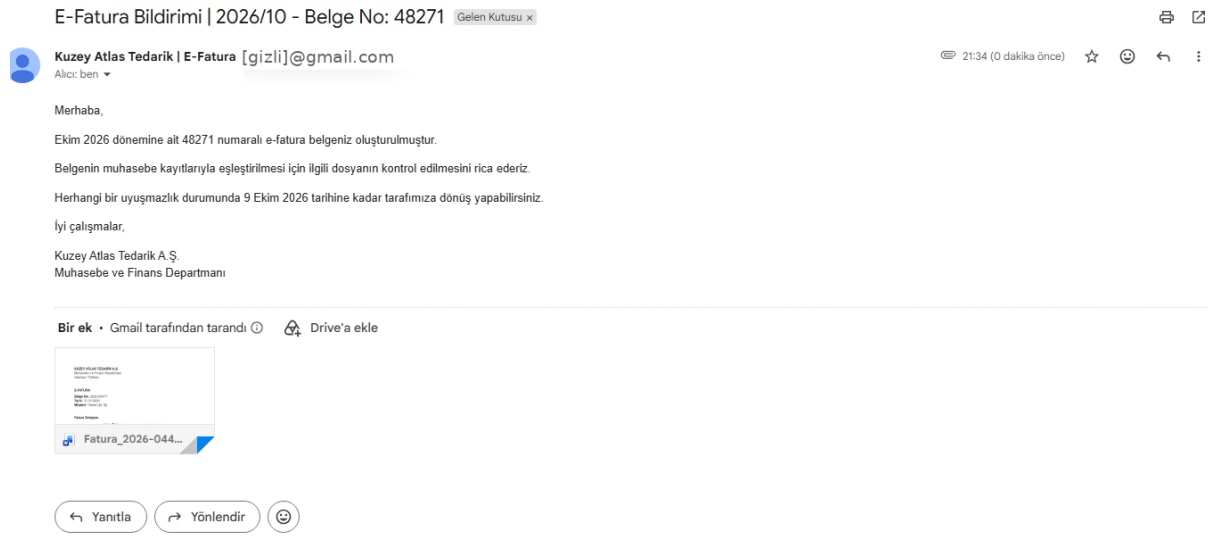
---

4. PHISHING SENARYOSU VE MAKRO SİMÜLASYONU

4.1. Phishing E-Postasının Analizi

Laboratuvar kapsamında Kuzey Atlas Tedarik şirketinin finans biriminden gönderilmiş gibi görünen bir e-fatura bildirimi hazırlandı.

E-postayı incelediğimde ilk dikkatimi çeken nokta, kurumsal bir finans biriminden gelmiş gibi görünmesine rağmen kişisel bir Gmail adresi üzerinden gönderilmiş olmasıydı. Bu tutarsızlık nedeniyle e-postanın phishing amaçlı olabileceğini değerlendirdim.



Şekil 2. Kuzey Atlas Tedarik adıyla oluşturulan e-fatura temalı test e-postası (temiz DOCX eki).

Ardından e-posta başlıklarını (header) inceleyerek SPF, DKIM ve DMARC sonuçlarını kontrol ettim.

SPF: Gönderen sunucunun ilgili alan adı adına e-posta gönderme yetkisini kontrol eder.

DKIM: Dijital imza aracılığıyla e-postanın doğrulanabilirliğini ve imzalanan içeriğin bütünlüğünü kontrol eder.

DMARC: SPF/DKIM sonuçlarının gönderen alan adıyla uyumunu değerlendirir ve alan adının belirlediği politikayı uygular.

Kontrollerin pass sonucunu verdiğini gördüm. Ancak bu sonuçların e-postanın tamamen güvenilir olduğunu kanıtlamadığını değerlendirdim. Özellikle görünen şirket kimliğiyle gerçek gönderen adresinin uyuşmaması şüpheli bir göstergeydi.


Orijinal İleti

İleti Kimliği	[ileti kimligi gizlendi]
Oluşturulma tarihi:	11 Ekim 2026 19:48 (14 saniye sonra teslim edildi)
Gönderen:	Kuzey Atlas Tedarik | E-Fatura <[gizli]@gmail.com>
Alıcı:	[gizli]@gmail.com
Konu:	E-Fatura Bildirimi | 2026/10 - Belge No: 48271
SPF:	209.85.220.41 IP numarası için SPF kimlik doğrulaması sonucu: PASS Daha fazla bilgi
DKIM:	gmail.com alanı için DKIM kimlik doğrulaması sonucu: 'PASS' Daha fazla bilgi
DMARC:	'PASS' Daha fazla bilgi

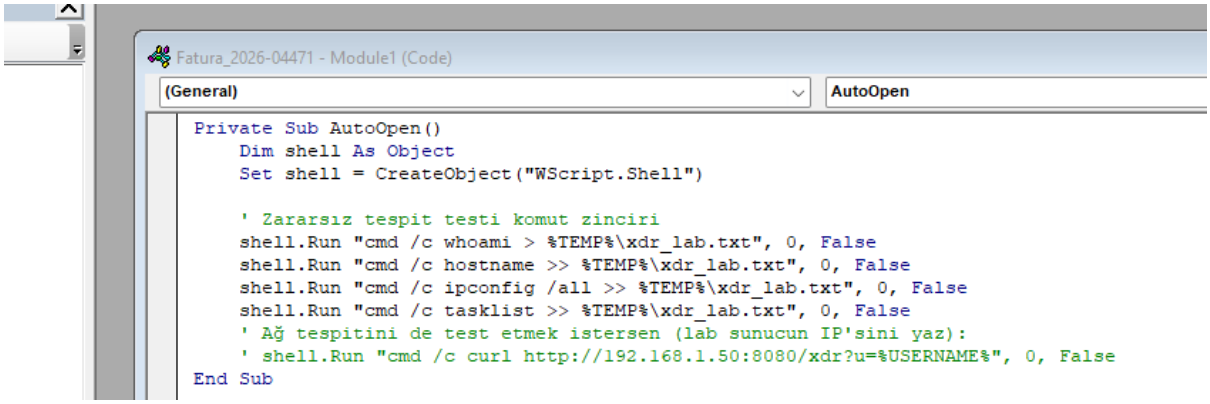
Şekil 3. Gmail orijinal ileti ekranında SPF, DKIM ve DMARC doğrulama sonuçları.

Bu nedenle yalnızca e-posta kimlik doğrulama sonuçlarına güvenmek yerine gönderen kimliğinin ve mesajın bağlamının birlikte değerlendirilmesi gerektiği sonucuna vardım.

Yayın notu: Ekran görüntülerindeki kişisel test e-posta adresleri gizlenmiştir; görsellerin teknik olay içerikleri değiştirilmemiştir.

4.2. Office Makro Simülasyonu

Phishing senaryosunun ardından Microsoft Word kullanarak Fatura_2026-04471.docm adlı makro destekli bir belge hazırladım. Belgenin içerisinde, açıldığında otomatik çalışacak şekilde AutoOpen() VBA makrosu tanımladım.



Şekil 4. Word VBA AutoOpen makrosu; yürütülen sistem keşif komutları ve yorum satırı.

İlk olarak makro içeren DOCM dosyasını Gmail üzerinden göndermeyi denedim. Ancak Gmail'in güvenlik kontrolleri dosyanın gönderilmesini engelledi. Bunun üzerine temiz bir DOCX dosyasını test hesapları arasında göndererek e-posta teslimatını doğruladım. Ayrıca yerel Mailpit ortamında DOCM ekiyle e-posta teslimatı gerçekleştirdim.

EDR/XDR incelemesini gerçekleştirmek amacıyla makro içeren DOCM dosyasını Windows 10 sanal makinesinde ayrı olarak çalıştırdım.

Makronun çalışmasıyla birlikte Word uygulaması üzerinden CMD başlatıldı ve aşağıdaki komutlar yürütüldü:

Komut	Amaç
whoami	Aktif kullanıcı hesabını öğrenmek
hostname	Bilgisayar adını öğrenmek
ipconfig /all	Sistem ve ağ yapılandırmasını incelemek
tasklist	Çalışan process'leri listelemek

Komutlardan elde edilen bilgiler %TEMP%\xdr_lab.txt dosyasına kaydedildi.

Bu komutlar tek başlarına zararlı olmasalar da saldırganlar tarafından sistem keşfi amacıyla kullanılabilir. Özellikle Word uygulamasının CMD üzerinden bu komutları çalıştırması, gerçek bir kurumsal ortamda şüpheli olarak değerlendirilmesi gereken bir davranıştır.

Simülasyon sonrasında komutların çalıştığını ve ilgili process aktivitelerinin TrendAI Vision One endpoint telemetrisine kaydedildiğini doğruladım.

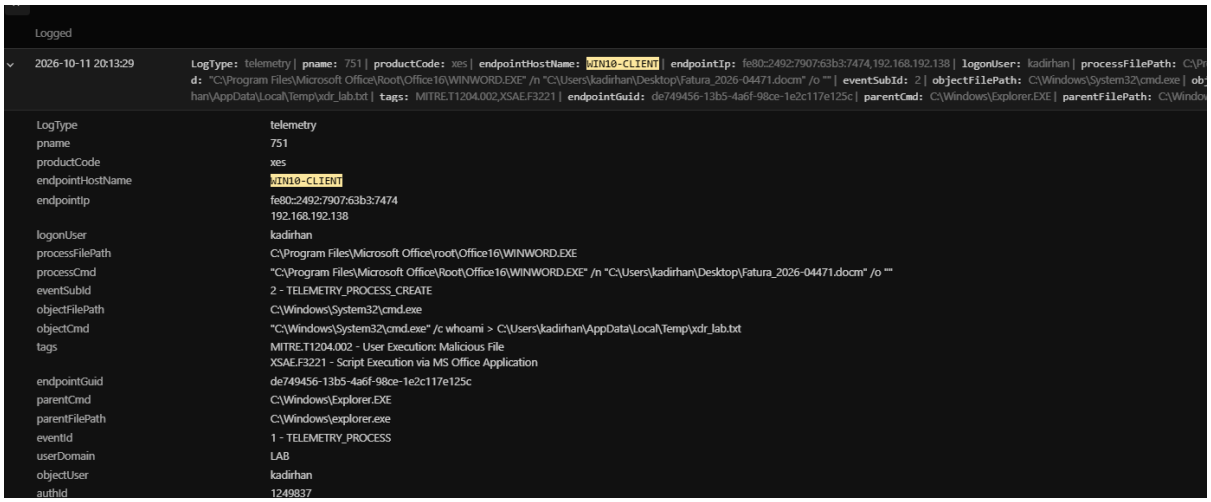
Çalışma kapsamında zararlı yazılım indirme, kalıcılık oluşturma, veri sızdırma veya yatay hareket uygulanmamıştır. VBA ekranındaki ek curl satırı yorum satırı olarak bırakılmıştır; bu işlem bu senaryoda yürütülmemiştir.

5. TEKNİK OLAY ANALİZİ

5.1. Process Creation Analizi

11 Ekim 2026 tarihinde gerçekleştirilen ilk simülasyonun ardından TrendAI Vision One XDR Data Explorer üzerinden endpoint aktiviteleri incelenmiştir.

Olay kayıtlarında Microsoft Word uygulamasının CMD başlattığı ve CMD üzerinden sistem keşfi komutlarının çalıştırıldığı görülmüştür.

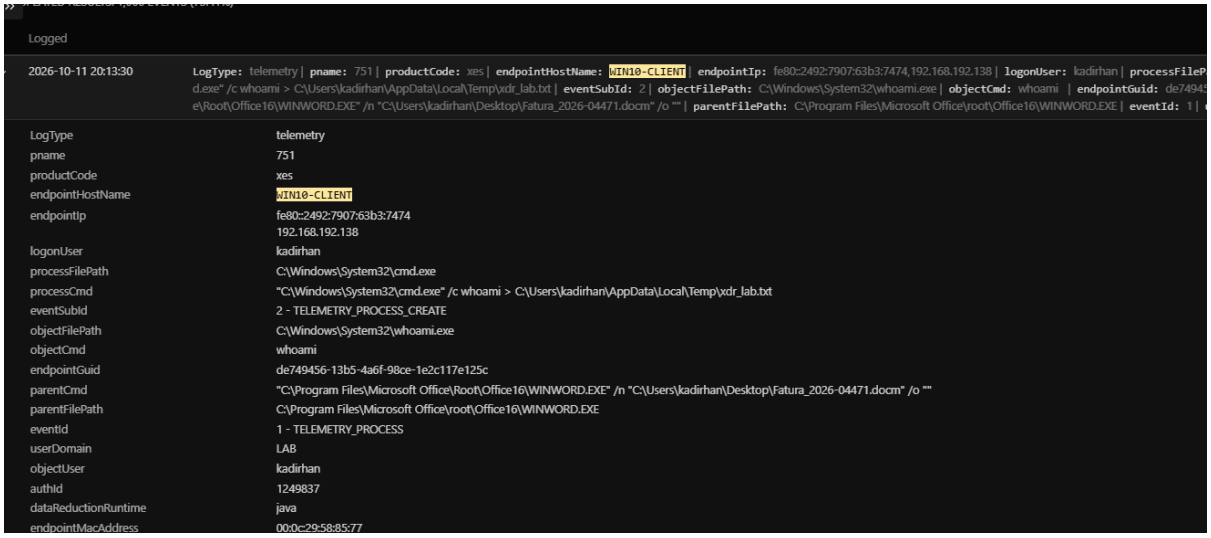


Şekil 5. XDR Data Explorer: WINWORD.EXE aktöründen cmd.exe oluşturma telemetrisi.

İlgili process zinciri:

explorer.exe → WINWORD.EXE → cmd.exe → whoami.exe

İlk testte Word uygulamasının WINWORD.EXE PID 4856 üzerinden cmd.exe PID 1880 sürecini başlattığı ve bu süreçten whoami.exe PID 4832'nin oluşturulduğu doğrulanmıştır.



Şekil 6. XDR Data Explorer: cmd.exe sürecinden whoami.exe başlatılması.

Process oluşturma kayıtlarında özellikle processName, objectFilePath, objectCmd, PID ve zaman bilgileri karşılaştırılmıştır.

Word uygulamasının CMD aracılığıyla sistem keşfi komutları çalıştırması, gerçek bir kurumsal ortamda araştırılması gereken şüpheli bir davranış olarak değerlendirilmiştir.

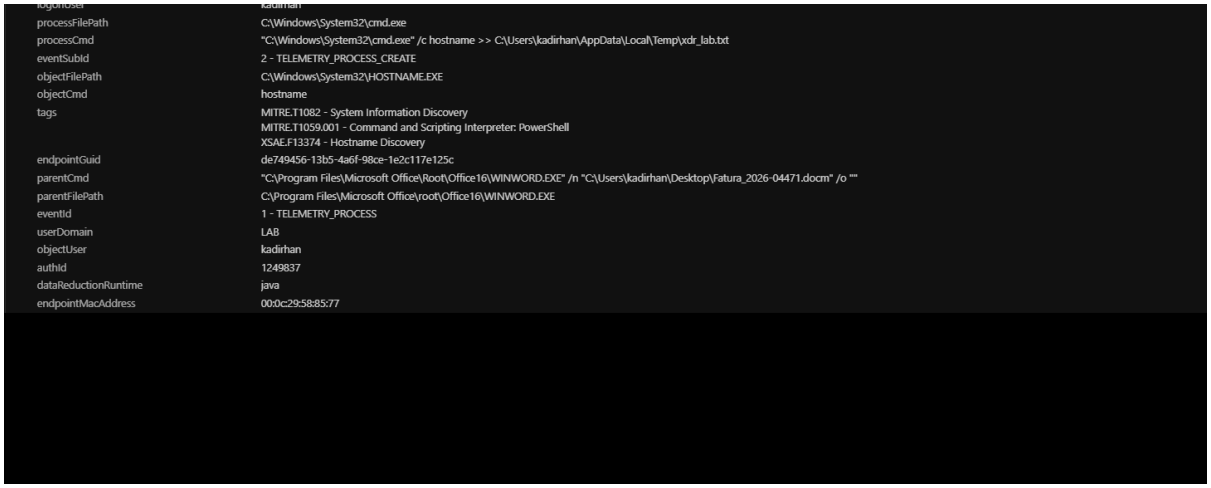
5.2. Komut Çalıştırma Bulguları

Makro aracılığıyla dört komut çalıştırılmıştır:

- whoami: Kullanıcı hesabı bilgisi

- hostname: Bilgisayar adı
- ipconfig /all: Ağ yapılandırması
- tasklist: Çalışan süreçler

Komut çıktıları %TEMP%\xdr_lab.txt dosyasına kaydedilmiştir.



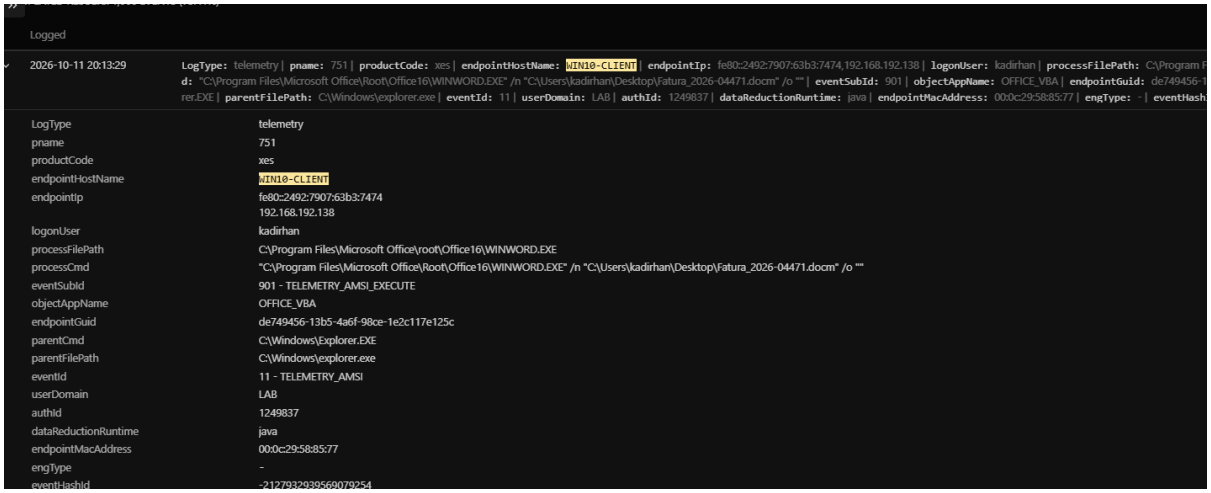
Şekil 7. XDR process creation kaydında tasklist çalıştırılması ve çıktı dosyası.

Bu komutlar tek başlarına zararlı değildir. Ancak Office uygulaması üzerinden beklenmedik şekilde çalıştırılmaları, sistem keşfi amacıyla kullanılan saldırgan davranışlarına benzediğinden güvenlik incelemesi gerektirmektedir.

5.3. AMSI Telemetrisinin İncelenmesi

XDR Data Explorer üzerinde Office VBA çalıştırma aktivitesiyle ilişkili AMSI kayıtları da incelenmiştir.

İlgili olayda TELEMETRY_AMSI, eventSubId: 901 ve OFFICE_VBA bilgileri gözlemlenmiştir.



Şekil 8. XDR Data Explorer: OFFICE_VBA ve TELEMETRY_AMSI_EXECUTE alanları.

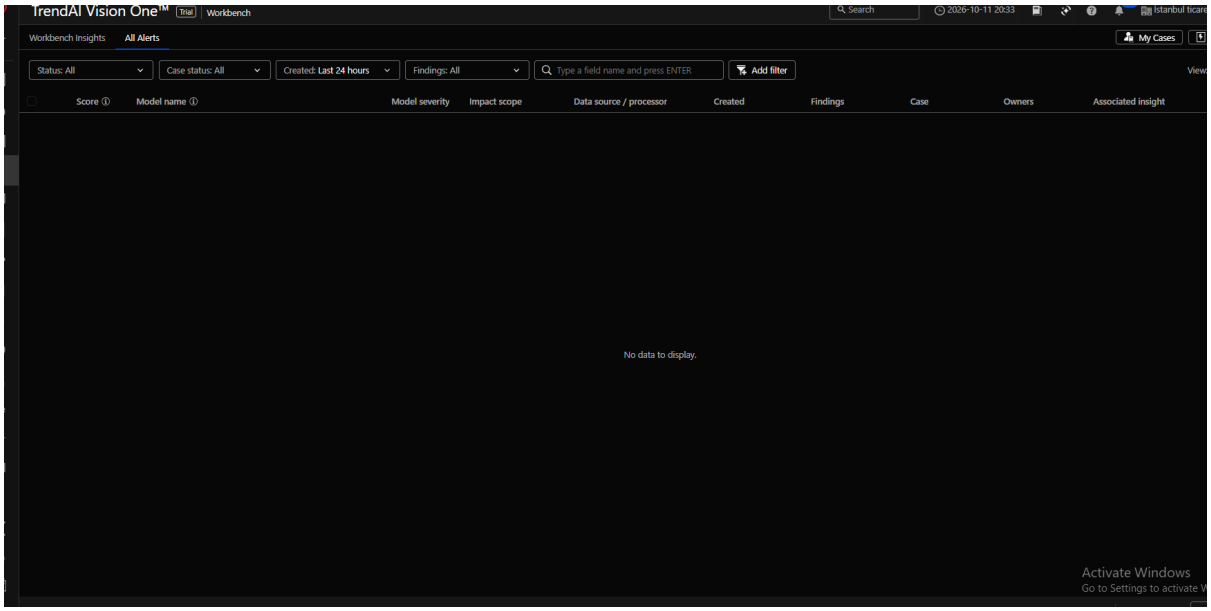
Bu kayıtlar, Office makro aktivitesine ilişkin ek telemetri bulunduğunu göstermiştir. Ancak AMSI kaydının oluşması tek başına makronun zararlı olarak sınıflandırıldığı veya engellendiği anlamına gelmemektedir.

---

6. DETECTION ENGINEERING

6.1. İlk Tespit Sonucu

İlk simülasyon sonrasında endpoint telemetrisi görüntülenmesine rağmen Workbench üzerinde otomatik bir alarm oluşmamıştır.

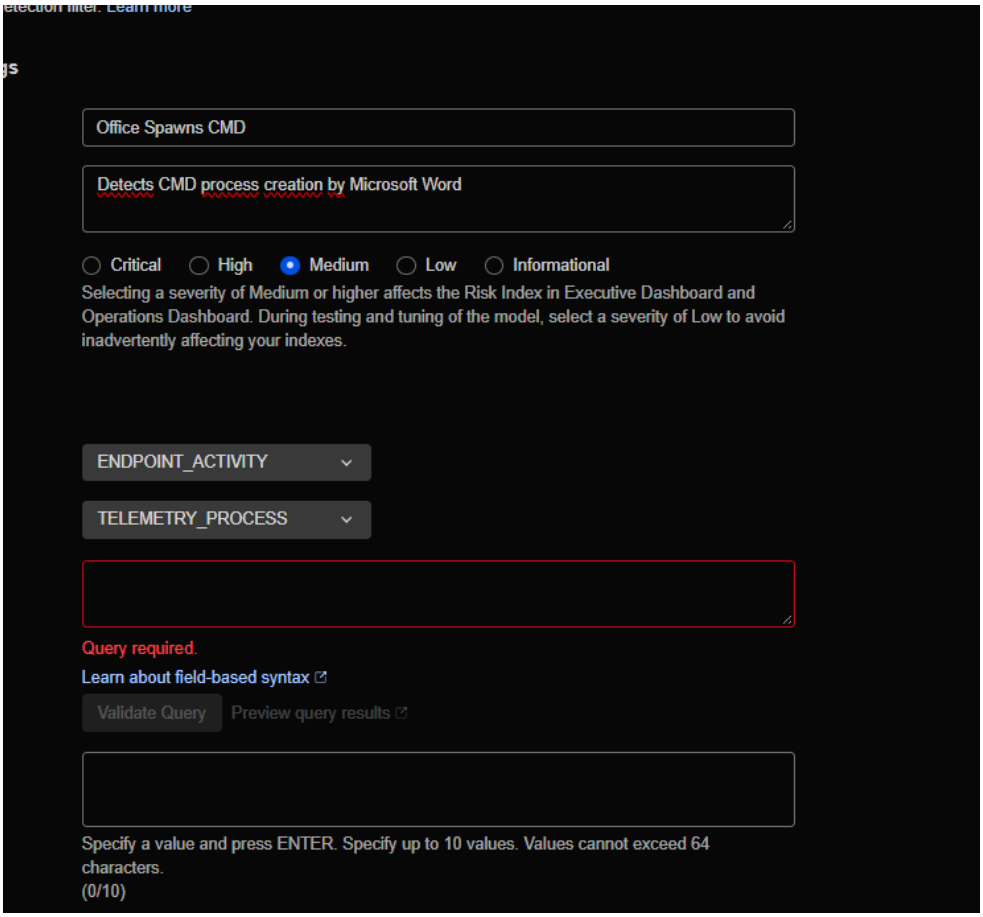


Şekil 9. İlk çalışma sonrasında Workbench All Alerts görünümünde alarm bulunmaması.

Bu durum, bir aktivitenin kaydedilmesiyle güvenlik alarmı oluşturulmasının farklı işlemler olduğunu göstermiştir.

6.2. Custom Detection Filter

Word uygulamasının CMD başlatmasını tespit etmek amacıyla Office Spawns CMD adlı özel bir filtre oluşturulmuştur.



Şekil 10. Custom Filter oluşturma ekranı; ad, event türü ve log türü alanları (sorgu girilmeden önce).

Event Type: ENDPOINT_ACTIVITY
Event ID: TELEMETRY_PROCESS

Kullanılan sorgu:

eventSubId:2 AND endpointHostName:"WIN10-CLIENT" AND processName:"*WINWORD.EXE" AND objectFilePath:"*cmd.exe"

Bu filtre, laboratuvar endpoint'inde Word tarafından başlatılan CMD süreçlerini tespit edecek şekilde yapılandırılmıştır. Sorgu doğrulanmış ve ilgili olaylarla eşleştiği görülmüştür.

6.3. Custom Detection Model

Oluşturulan filtre Suspicious Office CMD Execution adlı detection modeline bağlanmıştır.

Ayar	Değer
Severity	Low
Filter	Office Spawns CMD
Threshold	1
Frequency	15 minutes
Evaluation period	Last 15 minutes
Status	Enabled

Model etkinleştirildikten sonra makro yeniden çalıştırılmıştır.

İkinci testte komut çalıştırma olayları 11 Ekim 2026 saat 21:57:49–21:57:50 arasında gerçekleşmiş ve model tarafından Workbench alarmı oluşturulmuştur.

---

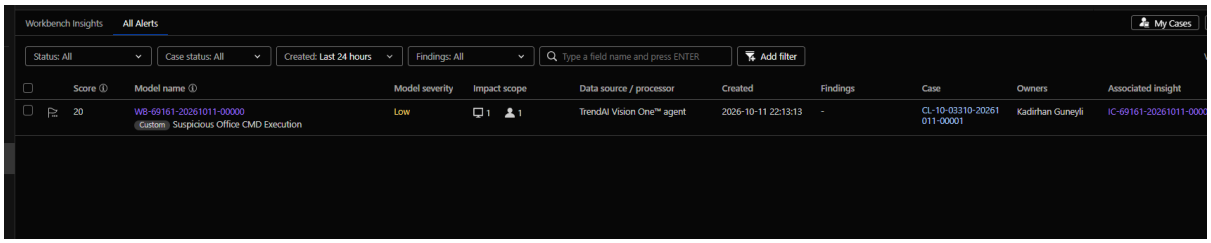
7. WORKBENCH ALERT INVESTIGATION

7.1. Alarm Bilgileri

Oluşturulan alarm TrendAI Vision One Workbench üzerinden incelenmiştir.

Alan	Değer
Alert Name	Suspicious Office CMD Execution
Alert ID	WB-69161-20261011-00000
Alert Time	11.10.2026 — 22:13:13
Alert Score	20
Model Severity	Low
Matching Events	4

Alarm, Word uygulamasının başlattığı dört ayrı CMD aktivitesini ilişkilendirmiştir.

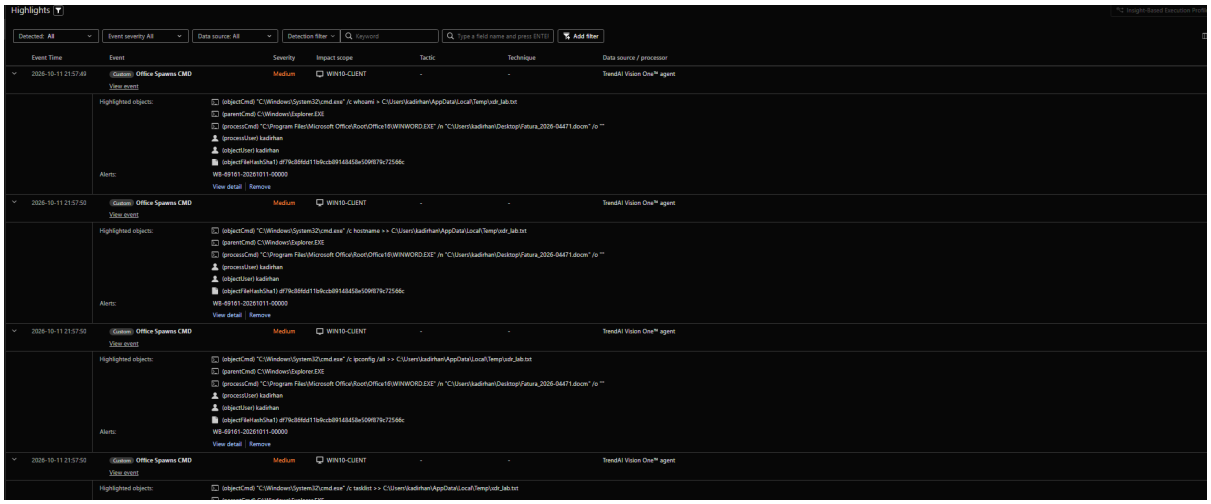


Şekil 11. Workbench All Alerts: özel modele ait alarm, skor ve kapsam bilgileri.

7.2. Timeline Analizi

Timeline bölümünde dört komut çalıştırma olayının zaman bilgileri karşılaştırılmıştır.

İnceleme sonucunda whoami, hostname, ipconfig /all ve tasklist komutlarının birbirine yakın zamanlarda çalıştırıldığı doğrulanmıştır.



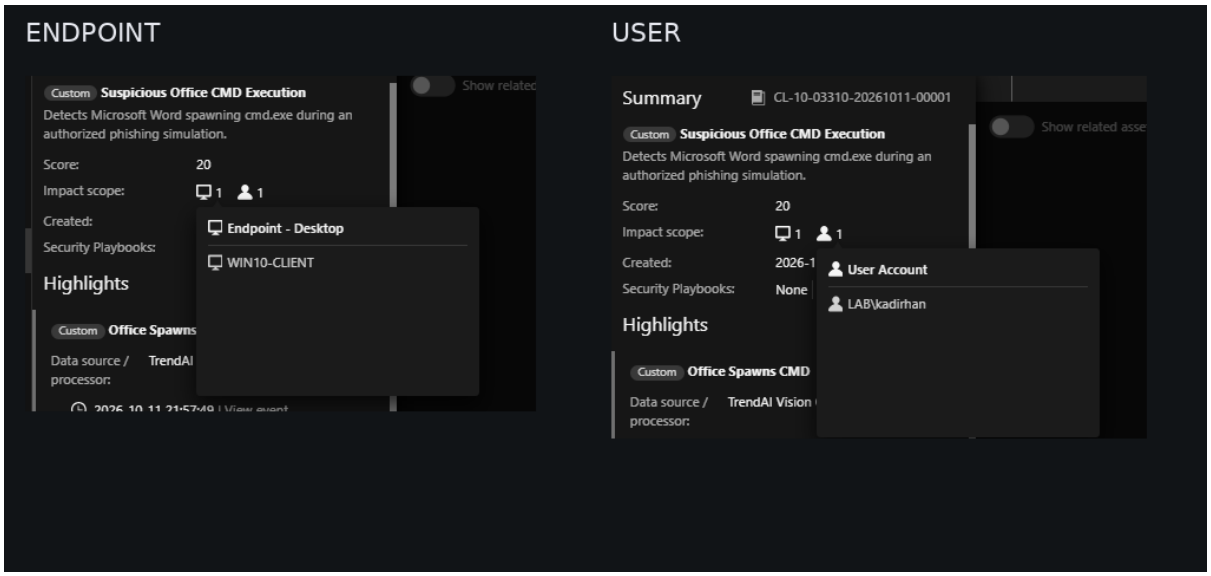
Şekil 12. Workbench Timeline: dört CMD aktivitesinin komut satırları ve zamanları.

7.3. Impact Scope

Impact Scope bölümünde alarmın ilişkili olduğu varlıklar incelenmiştir.

Endpoint: WIN10-CLIENT
User: LAB\kadirhan

Alarm kapsamında bir endpoint ve bir kullanıcı görüntülenmiştir.



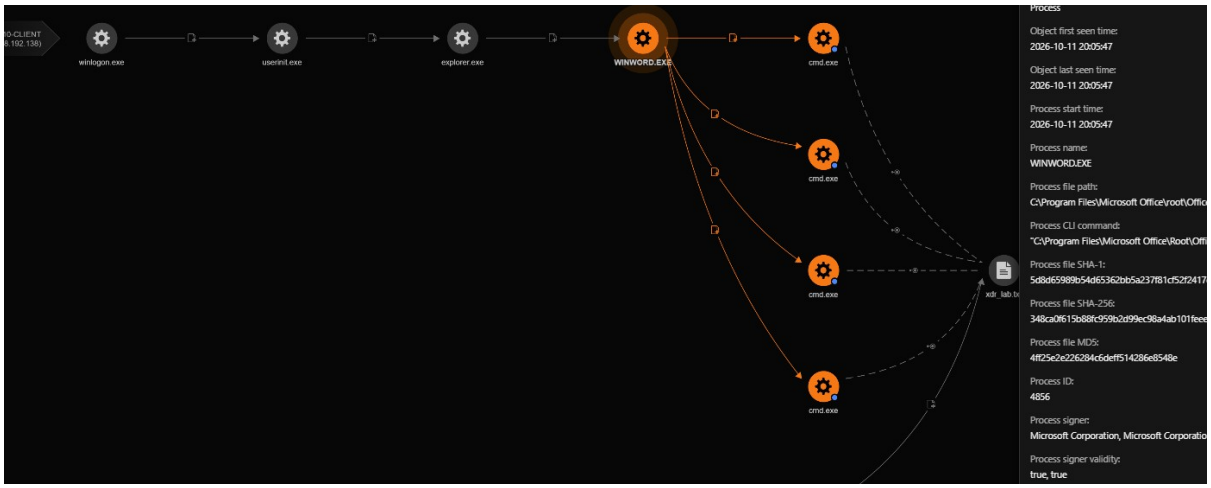
Şekil 13. Impact Scope: WIN10-CLIENT endpoint ve LAB\kadirhan kullanıcı hesabı (iki görünüm).

Ancak bu sonuç, laboratuvarın tamamında başka şüpheli faaliyet bulunmadığını tek başına kanıtlamamaktadır.

7.4. In-depth Investigation

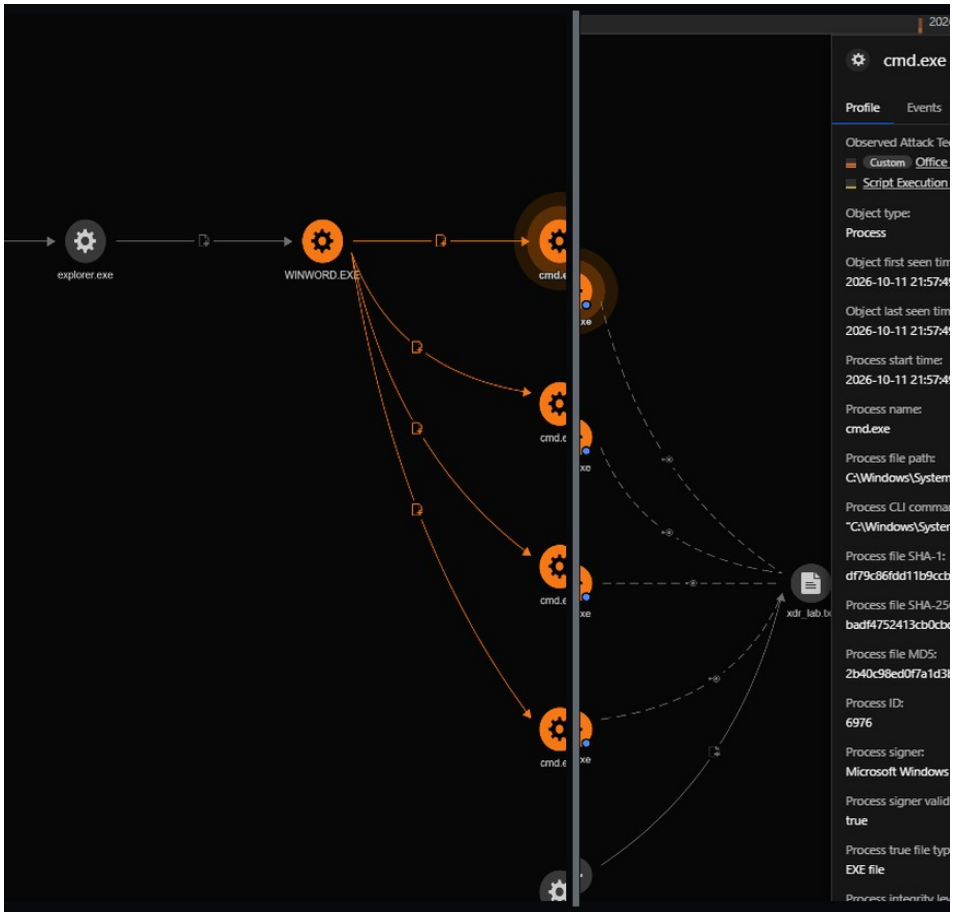
In-depth Investigation üzerinden olayın execution profile görünümü incelenmiştir.

Process ağacında explorer.exe → WINWORD.EXE → cmd.exe ilişkileri ve oluşturulan komut süreçleri görüntülenmiştir.



Şekil 14. In-depth Investigation: WINWORD.EXE tarafından dört cmd.exe sürecinin başlatılması.

Bu analiz sayesinde alarmın yalnızca sorguyla eşleştiği değil, ilişkili process davranışlarının da gerçek endpoint telemetrisiyle desteklendiği doğrulanmıştır.



Şekil 15. Execution Profile: cmd.exe process bilgileri, komut satırı ve hash alanları.

8. MITRE ATT&CK ANALİZİ

Laboratuvar kapsamında gözlemlenen davranışlar MITRE ATT&CK çerçevesiyle karşılaştırılmıştır.

Teknik	Açıklama	Laboratuvar karşılığı
T1204.002	User Execution: Malicious File	Kullanıcının makro içeren test belgesini açmasıyla benzer davranış
T1059.003	Windows Command Shell	CMD aracılığıyla komut çalıştırılması
T1033	System Owner/User Discovery	whoami
T1016	System Network Configuration Discovery	ipconfig /all
T1057	Process Discovery	tasklist
T1082	System Information Discovery	hostname ile sistem bilgisinin sorgulanması

Bu eşleştirmeler, simülasyonda gözlemlenen davranışların saldırganlar tarafından kullanılabilecek tekniklerle ilişkisini göstermektedir.

Teknik eşleştirmesi yapılması, aktivitenin gerçek bir saldırgan tarafından gerçekleştirildiği anlamına gelmemektedir.

---

9. SOC ANALİST DEĞERLENDİRMESİ

İnceleme sırasında Word uygulamasının CMD başlattığı ve sistem keşfi komutları çalıştırdığı doğrulanmıştır.

Bu davranışlar gerçek bir kurumsal ortamda gözlemlenseydi yalnızca komutların zararsız olduğu düşüncesiyle vaka kapatılmamalıydı. İlgili process ilişkileri, ağ bağlantıları, dosya aktiviteleri ve olası kalıcılık belirtileri araştırılmalıydı.

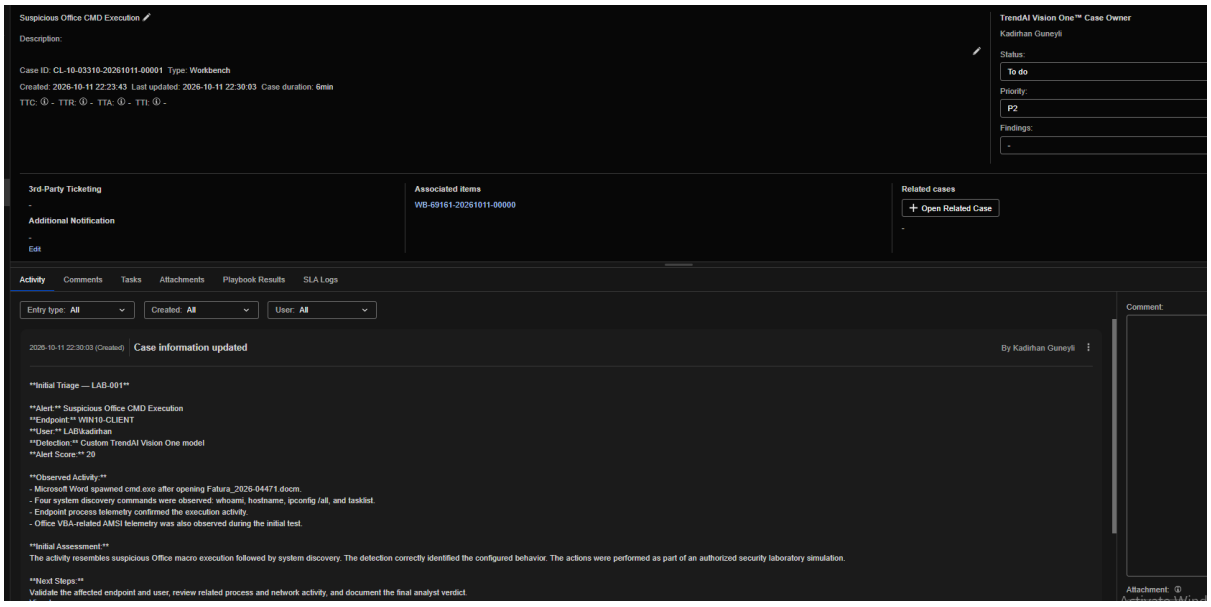
Mevcut vakada ise komutlar tarafımdan kontrollü bir laboratuvar simülasyonu kapsamında hazırlanmış ve çalıştırılmıştır.

Detection modeli hedeflenen davranışı doğru tespit etmiştir. Ancak yapılan incelemede gerçek bir saldırgan faaliyeti veya yetkisiz sistem ele geçirilmesi doğrulanmamıştır.

---

10. CASE CLOSURE

Workbench alarmının ardından bir SOC vakası oluşturulmuştur.



Şekil 16. SOC Case Management: oluşturulan vaka, olay kimliği ve ilk kayıt.

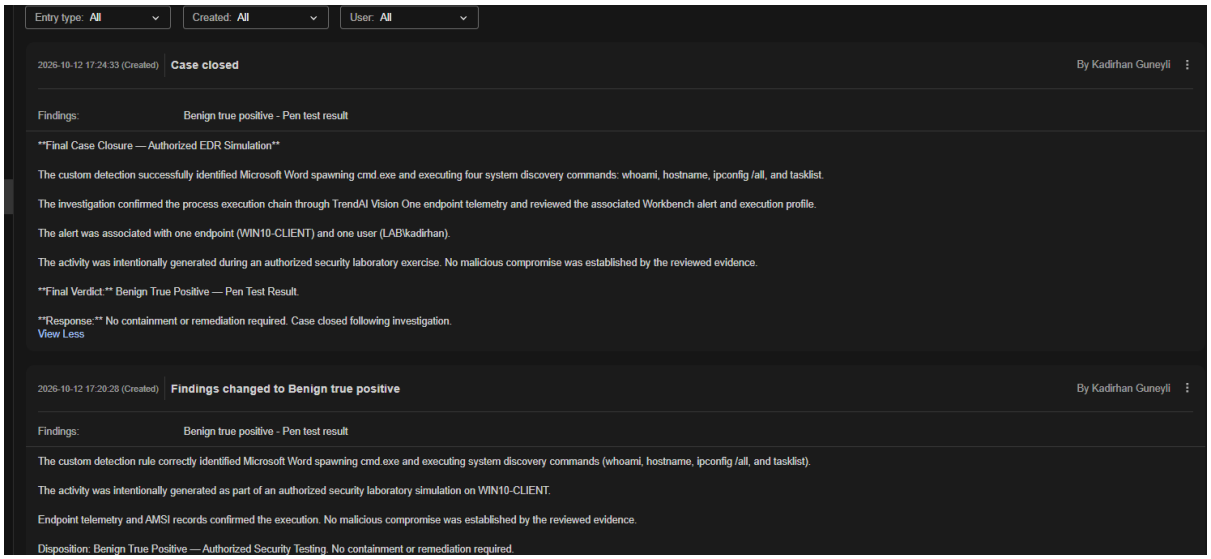
Case ID: CL-10-03310-20261011-00001
Associated Alert: WB-69161-20261011-00000
Final Status: Closed
Findings: Benign True Positive
Reason: Pen Test Result

Vaka kapsamında process telemetrisi, AMSI kayıtları, Timeline, Impact Scope ve In-depth Investigation bulguları değerlendirilmiştir.

Word üzerinden CMD çalıştırma davranışının gerçekten gerçekleştiği doğrulanmıştır. Ancak aktivitenin yetkili laboratuvar testinin parçası olması nedeniyle vaka **Benign True Positive** olarak sınıflandırılmıştır.

Gerçek bir güvenlik ihlali doğrulanmadığından endpoint izolasyonu veya zararlı yazılım temizleme müdahalesi uygulanmamıştır.

Vaka 12 Ekim 2026 tarihinde kapatılmıştır.



Şekil 17. Case Closure: Closed, Benign True Positive ve Pen Test Result kayıtları.

---

11. SONUÇ VE ÖNERİLER

Bu laboratuvar çalışmasında TrendAI Vision One EDR/XDR platformunun endpoint telemetrisi, özel tespit kuralları, Workbench alarm incelemesi ve SOC vaka yönetimi özellikleri uygulamalı olarak kullanılmıştır.

Word makrosu üzerinden oluşturulan şüpheli process davranışları analiz edilmiş, özel bir detection modeli geliştirilerek başarılı şekilde alarm üretilmiştir.

Çalışma, bir SOC analistinin yalnızca alarmı görmesinin değil, alarmı oluşturan olayları incelemesinin, kanıtları değerlendirmesinin ve gerekçeli bir vaka kapanış kararı vermesinin önemini göstermiştir.

Geliştirme önerileri: Özel detection kuralının farklı ve meşru Office aktiviteleriyle test edilerek yanlış alarm ihtimalinin değerlendirilmesi, tespit kapsamının genişletilmesi ve ayrı bir laboratuvarda endpoint izolasyonu ile müdahale süreçlerinin uygulanması önerilmektedir.

Bu çalışmanın temel hedefi olan **Detection → Investigation → Case Management → Closure** süreci tamamlanmıştır.